IT GOVERNANCE

Suggested Answers
November-December 2023

Answer to the Question# 1(a):

The action item been specified in National ICT Policy, 2009 to bolster culture, heritage and religion under the objective "Social Equity" is the following: Promote archiving and dissemination of multimedia content for indigenous culture, heritage and religion. The international organization among the primary actors for this action item is, UNESCO.

Answer to the Question# 1(b):

According to the National ICT Act 2006, "Computer source code" means the listing of programs, computer commands, design and layout and program analysis of computer resources in any form.

Answer to the Question# 1(c):

Cookies are small text files deposited on a computer hard drive when a user visits websites. Cookies identify the visitor's web browser software and track visits to the website. When the visitor returns to a site that has stored a cookie, the website software searches the visitor's computer, finds the cookie, and knows what that person has done in the past. It may also update the cookie, depending on the activity during the visit. In this way, the site can customize its content for each visitor's interests. For example, if you purchase a book on amazon.com and return later from the same browser, the site will welcome you by name and recommend other books of interest based on your past purchases. Websites using cookie technology cannot directly obtain visitors' names and addresses. However, if a person has registered at a site, that information can be combined with cookie data to identify the visitor. Website owners can also combine the data they have gathered from cookies and other website monitoring tools with personal data from other sources, such as offline data collected from surveys or paper catalog purchases, to develop very detailed profiles of their visitors.

Super cookies or Flash cookies cannot be easily deleted and can be installed whenever a person clicks a Flash video. Flash uses these so-called local shared object files to play videos and puts them on the user's computer without his or her consent.

Answer to the Question# 2(a):

Form Dimension

Clarity: Information should be provided in a form that is easy to understand.

Detail: Information can be provided in detail or summary form.

Order: Information can be arranged in a predetermined sequence.

Presentation: Information can be presented in narrative, numeric, graphic, or other forms.

Media: Information can be provided in the form of printed paper documents, video displays, or other media.

Answer to the Question# 2(b):

Market basket analysis (MBA) is one of the most common and useful types of data mining for marketing and is a key technique in business analytics. The purpose of market basket analysis is to determine which products customers purchase together with other products. MBA takes its name from the concept of customers throwing all of their purchases into a shopping cart (a market basket) during grocery shopping. It can be very helpful for a retailer or any other company to know which products people purchase as a group. A store could use this information to place products frequently sold together into the same area, and a catalog or World Wide Web merchant could use it to determine the layouts of a catalog and order form. Direct marketers could use the basket analysis results to determine which new products to offer their prior customers.

Here are some of the typical applications of MBA:

Cross Selling: Offer the associated items when customer buys any items from your store.

Product Placement: Items that are associated (such as bread and butter, tissues and cold medicine, potato chips and beer) can be put near each other. If the customers see them, it has higher probability that they will purchase them together.

Affinity Promotion: Design the promotional events based on associated products.

Survey Analysis: The fact that both independent and dependent variables of market basket analysis are nominal (categorical) data type makes MBA very useful to analyze questionnaire data.

Fraud Detection: Based on credit card usage data, we may be able to detect certain purchase behaviors that can be associated with fraud.

Customer Behavior: Associating purchase with demographic, and socioeconomic data (such as age, gender, and preference) may produce very useful results for marketing.

Answer to the Question# 2(c):

An enterprise information portal (EIP) is a Web-based interface and integration of MIS, DSS, EIS, and other technologies that give all intranet users and selected extranet users access to a variety of internal and external business applications and services. For example, internal applications might include access to e-mail, project Web sites, and discussion groups; human resources Web self-services; customer, inventory, and other corporate databases; decision support systems; and knowledge management systems. External applications might include industry, financial, and other Internet news services; links to industry discussion groups; and links to customer and supplier Internet and extranet Web sites. Enterprise information portals are typically tailored or personalized to the needs of individual business users or groups of users, giving them a personalized digital dashboard of information sources and applications.

Answer to the Question# 2(d):

In a blockchain system, each event exists as one single version of the event stored onto a database and distributed to relevant parties. The blockchain consensus mechanism aligns all the entities to have the same view of the event. This happens without a third party, and it is enabled by protocols that ensure that each entity independently checks that data conforms to the technical and business rules that they originally agreed upon.

Answer to the Question# 2(e):

It is not possible to define the term "FinTech" on the basis of its use in legislation or legal documents. FinTech companies are subject to differing kinds of legal and regulatory obligations due to their differing business models and the extremely diverse products and services they offer. Companies in the crowdinvesting industry offering profit-participating loans, non-securitized participation rights or silent partnerships to secure corporate financing fall under the scope of investment act. However, issuers on the same crowdinvesting platforms are subject to the securities trading act if shares are sold to the crowd. In the end, it is not possible to construct a restrictive definition of "FinTech" that applies to all of the entities traditionally associated with the term. While most companies in the FinTech industry have certain features in common, there are always enough exceptions to render them inadequate for producing a general definition. For example, many of the FinTech companies are in their start-up phase. However, since not all FinTech companies are start-ups, this category cannot be an essential part of a FinTech definition. The same applies to the participation of a large number of investors in a funding opportunity (the "crowd") or the use of social-media components. Although these two features are integral to the operation of many segments of the FinTech industry, such as in crowdfunding or social trading, there are others, such as innovative payment services, where they have no importance at all.

Answer to the Question# 3(a):

IT governance offers a framework to synchronize IT strategy with business strategy, enabling organizations to generate quantifiable outcomes that advance their strategic goals. This structured approach takes into consideration stakeholders' concerns, staff requirements, and operational procedures. Given that my friend and I have distinct business strategies, we can adopt formal IT governance frameworks that harmonize our respective business strategies with IT strategies.

Now, our strategies revolve around risk management and performance. As a result, we have the option to implement frameworks such as COBIT5 for risk management and mitigation, COSO for enterprise risk management (ERM) and fraud deterrence, CMMI for enhancing performance, and FAIR for addressing cybersecurity and operational risk. These choices are aimed at facilitating our respective business strategies.

Answer to the Question# 3(b):

Transforming a startup into an organization involves adopting key characteristics commonly found in modern organizations. These include establishing a bureaucratic structure with clear divisions of labor and specialization. Within this structure, specialists are organized hierarchically, with each person being accountable to someone and exercising authority in accordance with specific rules and procedures.

Furthermore, it's essential to prioritize hiring and promoting employees based on their technical qualifications and professionalism rather than personal connections. Organizations are also shaped by their business processes, organizational culture, politics, the external environment, structure, goals, constituencies, and leadership styles, all of which have a significant impact on the types of information systems employed. Embracing these characteristics and principles will help a startup evolve into a well-established organization.

Answer to the Question# 3(c):

Applying Porter's Competitive Forces Model to an organization involves considering the five key competitive components. They are:

1. Traditional Competitors: This represents the rivalry among existing competitors in the industry. It is crucial to understand how your organization stacks up against these competitors.
2. New Market Entrants: Assessing the threat of new entrants is vital. Factors such as barriers to entry, regulatory hurdles, and economies of scale influence the potential for new competition.
3. Substitute Products and Services: Understanding the availability and appeal of substitute products or services that could lure customers away from your offerings is essential for strategic planning.
4. Customers: Evaluating the bargaining power and preferences of your customers helps in tailoring your strategies to meet their needs and maintain loyalty.
5. Suppliers: Analyzing the power suppliers hold over your organization, including their ability to impact costs and supply, is critical.

Although the Porter model is very helpful for identifying competitive forces and suggesting generic strategies, it is not very specific about what exactly to do, and it does not provide a methodology to follow for achieving competitive advantages. Here’s where the business value chain model is helpful. The value chain model highlights specific activities in the business where competitive strategies can best be applied and where information systems are most likely to have a strategic impact. This model identifies specific, critical leverage points where a firm can use information technology most effectively to enhance its competitive position. So by providing the specific methodology, it solves the problem of Porter's model.

Answer to the Question# 3(d):

There are four generic strategies, each of which is often enabled by using information technol-ogy and systems. These are:

- low-cost leadership
- product differentiation
- focus on market niche, and
- strengthening customer and supplier intimacy.

By applying these strategies, one can outperform its competitive organizations.

Answer to the Question# 4(a):

The organization running web services should be aware of the following cyber attacks:

- DoS attack: Deniol of Service (DoS) attack can make web services unavailable
- SQL injection attack: SQL injection attack can leak or modify the data in the database of the web system.
- Distributed Denial of Service (DDoS): It might severely hamper the quality of services as it's a stronger version of DoS attack.
- Man in the middle attack: It might leak credentials and confidential information about a user.

Answer to the Question# 4(b):

Pirated software may contain malicious malware. Malicious software contains viruses, worms, trojan horses, ransomware, or spyware.

- Viruses might destroy programs or data, clog computer memory, reformat a computer's hard drive, or cause programs to run improperly.
- Worms can self replicate on other systems and cause virus-like destruction.
- A Trojan horse is a software program that appears to be benign but then does something other than expected.
- Ransomware tries to extort money from users by taking control of their computers or displaying annoying pop-up messages
- Adware installs itself surreptitiously on computers to monitor user web-surfing activity and serve up advertising.

So installing pirated software may cause the above mentioned problems in the system.

Answer to the Question# 4(c):

A distributed denial-of-service (DDoS) attack uses numerous computers to inundate and overwhelm the network from numerous launch points.

Perpetrators of DDoS attacks often use thousands of zombie PCs infected with malicious software without their owners' knowledge and organized into a botnet. Hackers create these botnets by infecting other people's computers with bot malware that opens a back door through which an attacker can give instructions. The infected computer then becomes a slave, or zombie, serving a master computer belonging to someone else. When hackers infect enough computers, they can use the amassed resources of the botnet to launch DDoS attacks.

Answer to the Question# 4(d):

An organization should adopt information system controls to prevent 'Stuxnet' like cyber attack. Information system controls consist of general and application controls.

General controls govern the design, security, and use of computer programs and the security of data files in general throughout the organization's information technology infrastructure. On the whole, general controls apply to all computerized applications and consist of a combination of hardware, software, and manual procedures that create an overall control environment.

Application controls are specific controls unique to each computerized application, such as payroll or order processing. They include both automated and manual procedures that ensure that only authorized data are completely and accurately processed by that application. Application controls can be classified as (1) input controls, (2) processing controls, and (3) output controls. Input controls check data for accuracy and completeness when they enter the system. Processing controls establish that data are complete and accurate during updating. Output controls ensure that the results of computer processing are accurate, complete, and properly distributed.

Answer to the Question# 4(e):

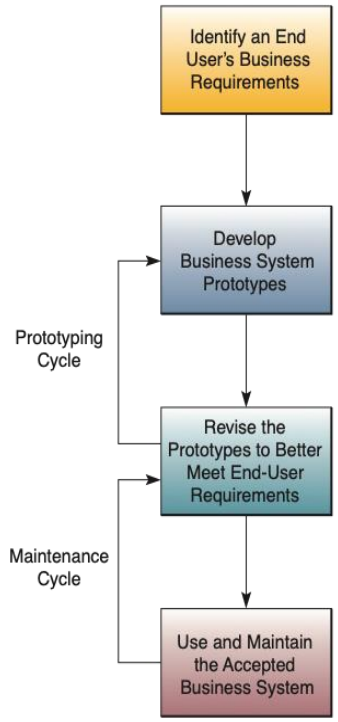
Technologies and tools that an organization should use for safeguarding its information resources are as follows:

- Firewalls prevent unauthorized users from accessing a private network when it is linked to the Internet.
- Intrusion detection systems monitor private networks for suspicious network traffic and attempts to access corporate systems.
- Passwords, tokens, smart cards, and biometric authentication are used to authenticate system users.
- Antivirus software checks computer systems for infections by viruses and worms and often eliminates the malicious software; anti-spyware software combats intrusive and harmful spyware programs.
- Encryption, the coding and scrambling of messages, is a widely used technology for securing electronic transmissions over unprotected networks.
- Digital certificates combined with public key encryption provide further protection for electronic transactions by authenticating a user's identity.
- Companies can use fault-tolerant computer systems to make sure that their information systems are always available.
- The use of software metrics and rigorous software testing help improve software quality and reliability.

Challenges that may result from organizations using information technology in its business model are as follows:

- Security Challenges: Protecting sensitive data from cyber threats and ensuring the confidentiality, integrity, and availability of information is a constant battle for organizations.
- Ethical Challenges: Balancing innovation with ethical considerations like data privacy, transparency, and responsible AI use is vital for maintaining public trust.
- Employment Challenges: Automation and digital transformation can disrupt traditional employment models, necessitating workforce reskilling and adaptation.
- Computer Monitoring: The practice of monitoring employee computer usage raises concerns about privacy and surveillance in the workplace.
- Challenges in Working Conditions: Remote work and technology integration require addressing work-life balance, mental health, and ergonomic concerns.
- Challenges of Individuality: The influence of algorithms and data profiling on individual decision-making and behavior raises questions about autonomy and personal freedom.
- Health Issues: Prolonged screen time and digital device use can contribute to physical and mental health problems, necessitating awareness and mitigation strategies.

Answer to the Question# 5(a):



Answer to the Question# 5(b):

Tangible Benefits

- Increase in sales or profits. Example: Development of IT-based products.
- Decrease in information processing costs. Example: Elimination of unnecessary documents.
- Decrease in operating costs. Example: Reduction in inventory carrying costs.
- Decrease in required investment. Example: Decrease in inventory investment required.
- Increased operational efficiency. Example: Less spoilage, waste, and idle time.

Intangible Benefits

- Improved information availability. Example: More timely and accurate information.
- Improved abilities in analysis. Example: OLAP and data mining.
- Improved customer service. Example: More timely service response.
- Improved employee morale. Example: Elimination of burdensome job tasks.
- Improved management decision making. Example: Better information and decision analysis.
- Improved competitive position. Example: Systems that lock in customers.
- Improved business image. Example: Progressive image as perceived by customers, suppliers, and investors.

Answer to the Question# 5(c):

Ten major hardware evaluation factors are as follows:

1. Performance
   What is its speed, capacity, and throughput?
2. Cost
   What is its lease or purchase price? What will be its cost of operation and maintenance?
3. Reliability
   What are the risk of malfunction and its maintenance requirements? What are its error control and diagnostic features?
4. Compatibility
   Is it compatible with existing hardware and software? Is it compatible with hardware and software provided by competing suppliers?
5. Technology
   In what year of its product life cycle is it? Does it use a new untested technology, or does it run the risk of obsolescence?
6. Ergonomics
   Has it been "human factors engineered" with the user in mind? Is it user-friendly, designed to be safe, comfortable, and easy to use?
7. Connectivity
   Can it be easily connected to wide area and local area networks that use different types of network technologies and bandwidth alternatives?
8. Scalability
   Can it handle the processing demands of a wide range of end users, transactions, queries, and other information processing requirements?
9. Software
   Are system and application software available that can best use this hardware?
10. Support
    Are the services required to support and maintain it available?

Answer to the Question# 5(d):

Four basic categories of maintenance are: (1) corrective, (2) adaptive, (3) perfective, and (4) preventive.

The activities associated with corrective maintenance are focused on fixing bugs and logic errors not detected during the implementation testing period.

Adaptive maintenance refers to those activities associated with modifying existing functions or adding new functionality to accommodate changes in the business or operating environments.

Perfective maintenance activities involve changes made to an existing system that are intended to improve the performance of a function or interface.

The final category of maintenance activities, preventive maintenance, involves those activities intended to reduce the chances of a system failure or extend the capacity of a current system's useful life. Although often the lowest-priority maintenance activity, preventive maintenance is, nonetheless, a high-value-adding function and is vital to an organization realizing the full value of its investment in the system.

Answer to the Question# 6(a):

All of the relevant processes that represent the blueprint of the entity's business should be included in the audit universe. The audit universe ideally lists all of the processes that may be considered for audit. Each of these processes may be subjected to a qualitative or quantitative risk assessment by evaluating the risk in respect to defined, relevant risk factors. The risk factors are those factors that influence the frequency and/or business impact of risk scenarios. For example, for an entity engaged in retail business, reputation can be a critical risk factor. The evaluation of risk should ideally be based on inputs from the business process owners.

Answer to the Question# 6(b):

ITAF is a comprehensive and good practice-setting reference model that:

- Establishes standards that address IS audit and assurance professional roles and responsibilities; knowledge and skills; and diligence, conduct and reporting requirements.
- Defines terms and concepts specific to IS assurance.
- Provides guidance and tools and techniques on the planning, design, conduct and reporting of IS audit and assurance assignments.

ITAF is focused on ISACA material and provides a single source through which IS audit and assurance professionals can seek guidance, research policies and procedures, obtain audit and assurance programs, and develop effective reports.

Answer to the Question# 6(c):

In order to attain the IS control objectives of ensuring integrity of sensitive and critical application system environments in the context of auditing, the following issues are to be considered:

- Authorization of the input. Each transaction is authorized and entered only once.
- Validation of the input. Each input is validated and will not cause negative impact to the processing of transactions.
- Accuracy and completeness of processing of transactions.
- All transactions are recorded accurately and entered into the system for the proper period.
- Reliability of overall information processing activities.
- Accuracy, completeness and security of the output.
- Database confidentiality, integrity and availability.

Answer to the Question# 6(d):

Forensic auditing has been defined as auditing specialized in discovering, disclosing and following up on fraud and crimes. The primary purpose of such a review is the development of evidence for review by law enforcement and judicial authorities. Forensic professionals have been called on to participate in investigations related to corporate fraud and cybercrime. In cases where computer resources may have been misused, further investigation is necessary to gather evidence for possible criminal activity that can then be reported to appropriate authorities. A computer forensic investigation includes the analysis of electronic devices such as computers, smartphones, disks, switches, routers, hubs and other electronic equipment.

An IS auditor possessing the necessary skills can assist the information security manager in performing forensic investigations and conduct the audit of the systems to ensure compliance with the evidence collection procedures for forensic investigation. Electronic evidence is vulnerable to changes; therefore, it is necessary to handle electronic evidence with utmost care and controls should ensure that no manipulation can occur. Chain of custody for electronic evidence should be established to meet legal requirements.

Improperly handled computer evidence is subject to being ruled inadmissible by judicial authorities. The most important consideration for a forensic auditor is to make a bit-stream image of the target drive and examine that image without altering date stamps or other information attributable to the examined files. Further, forensic audit tools and techniques such as data mapping for security and privacy risk assessment, and the search for intellectual property for data protection, are also being used for prevention, compliance and assurance.

Answer to the Question# 6(e):

The concept of materiality is a key issue when deciding which findings to bring forward in an audit report. Key to determining the materiality of audit findings is the assessment of what would be significant to different levels of management.

Assessment requires judging the potential effect of the finding if corrective action is not taken. A weakness in computer security physical access controls at a remote distributed computer site may be significant to management at the site but will not necessarily be material to upper management at headquarters. However, there may be other matters at the remote site that would be material to upper management.

The IS auditor must use judgment when deciding which findings to present to various levels of management. For example, the IS auditor may find that the transmittal form for delivering tapes to the offsite storage location is not properly initialed or authorization evidenced by management as required by procedures. If the IS auditor finds that management otherwise pays attention to this process and that there have been no problems in this area, the IS auditor may decide that the failure to initial transmittal documents is not material enough to bring to the attention of upper management. The IS auditor might decide to discuss this only with local operations management. However, there may be other control problems that will cause the IS auditor to conclude that this is a material error because it may lead to a larger control problem in other areas. The IS auditor should always judge which findings are material to various levels of management and report them accordingly.

---The End---